

Informe FAIR-STRIDE.

FAIR-STRIDE es, hoy, el matrimonio de conveniencia entre dos mundos que antes apenas se hablaban: el de la cuantificación económica del riesgo (FAIR) y el del modelado estructurado de amenazas (STRIDE), aplicado ya en 2025-2026 a programas nacionales de ciberresiliencia, especialmente en países que han abrazado Zero Trust, regulación sectorial dura y supervisión financiera estricta.¹²³⁴⁵

1. FAIR-STRIDE: de qué estamos hablando realmente

FAIR aporta el esqueleto cuantitativo: frecuencia de eventos de pérdida y magnitud de la pérdida, todo en euros, no en colores de semáforos. STRIDE aporta la taxonomía de por dónde se nos cuela la miseria: suplantación, manipulación, repudio, divulgación, denegación de servicio y elevación de privilegios. FAIR-STRIDE, tal y como se ha ido formulando desde ponencias como la de Arthur Loris en BSidesSF y su posterior adopción por comunidades de threat modeling, consiste en mapear cada amenaza STRIDE a

1 [https://www.fairinstitute.org/hubfs/FAIR Institute -- Comply with ISO_IEC%2027001%20with%20FAIR%20\(March %202025\).pdf](https://www.fairinstitute.org/hubfs/FAIR%20Institute%20Comply%20with%20ISO%20IEC%2027001%20with%20FAIR%20(March%202025).pdf)

2 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

3 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

4 <https://www.fairinstitute.org/state-of-crm-2025>

5 <https://www.youtube.com/watch?v=EhQcKcfIbxY>

factores FAIR, de forma que cada escenario STRIDE tenga una distribución de frecuencia y pérdida que pueda entrar en simulaciones tipo Monte Carlo y agregarse a exposición anual de pérdida.⁶⁷⁸⁹¹⁰¹¹¹²¹³¹⁴¹⁵¹⁶¹⁷¹⁸¹⁹

Esto permite responder preguntas políticamente incorrectas pero imprescindibles: “¿vale más la pena arreglar dos vulnerabilidades críticas asociadas a elevación de privilegios o 47 medias relacionadas con repudio y trazabilidad?”, y contestarlas en coste esperado anual, percentiles y ROI de controles, no en “impacto alto/medio/bajo”. La tendencia post-2025 es clara: la cuantificación FAIR ha dejado de ser excentricidad académica y se aproxima al mainstream, con casi la mitad de las organizaciones grandes declarando uso o intención de uso de FAIR, y éxito percibido muy elevado entre quienes lo adoptan.²⁰²¹²²

6 [https://es.wikipedia.org/wiki/STRIDE_\(seguridad\)](https://es.wikipedia.org/wiki/STRIDE_(seguridad))

7 <https://www.purestorage.com/es/knowledge/stride-threat-model.html>

8 <https://www.youtube.com/watch?v=8nMfIR57tLg>

9 <https://atlansec.es/es/blog/posts/16-03-2025/>

10 <https://www.cloudflare.com/es-es/learning/security/glossary/what-is-threat-modeling/>

11 <https://www.toreon.com/tmi-newsletter-27-unleashing-the-power-of-threat-modeling/>

12 <https://fastercapital.com/topics/conducting-a-security-audit.html/1>

13 <https://fastercapital.com/topics/conducting-security-risk-assessment.html/1>

14 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

15 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

16 <https://www.fairinstitute.org/state-of-crm-2025>

17 [https://www.fairinstitute.org/hubfs/FAIR Institute -- Comply with ISO_IEC%2027001%20with%20FAIR%20\(March %202025\).pdf](https://www.fairinstitute.org/hubfs/FAIR%20Institute%20--%20Comply%20with%20ISO_IEC%2027001%20with%20FAIR%20(March%202025).pdf)

18 <https://trepo.tuni.fi/bitstream/10024/143248/2/KiviojaSini.pdf>

19 [https://www.fairinstitute.org/hubfs/FAIR Institute -- Comply with ISO_IEC%2027001%20with%20FAIR%20\(March %202025\).pdf](https://www.fairinstitute.org/hubfs/FAIR%20Institute%20--%20Comply%20with%20ISO_IEC%2027001%20with%20FAIR%20(March%202025).pdf)

20 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

21 <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

22 [https://www.fairinstitute.org/hubfs/FAIR Institute -- Comply with ISO_IEC%2027001%20with%20FAIR%20\(March %202025\).pdf](https://www.fairinstitute.org/hubfs/FAIR%20Institute%20--%20Comply%20with%20ISO_IEC%2027001%20with%20FAIR%20(March%202025).pdf)

2. Tendencias 2025-2026 en indicadores FAIR-STRIDE

Desde 2025 se observa una convergencia entre marcos de gestión de riesgos (ISO 27001/27005, NIST RMF) y FAIR, con documentos formales que explican cómo usar FAIR para cumplir requisitos de evaluación de riesgos de confidencialidad, integridad y disponibilidad, traduciendo las pérdidas en términos financieros trazables. Los modelos de amenazas tipo STRIDE se integran como “fábricas de escenarios” dentro de esos procesos, aportando sistemática para identificar vectores que luego FAIR cuantifica.²³²⁴²⁵²⁶²⁷²⁸²⁹³⁰

En threat modeling avanzado, se consolida la práctica de descomponer sistemas en componentes, definir límites de confianza, mapear flujos de datos y etiquetar cada interacción con las categorías STRIDE, para después estimar, para cada amenaza, frecuencia de amenaza, vulnerabilidad (probabilidad de éxito), impacto primario (operativo, técnico) y secundario (regulatorio, reputacional, litigios), según la terminología FAIR. Las herramientas de simulación (por ejemplo, hojas de cálculo con extensiones de Monte Carlo) se utilizan para transformar todo esto en distribuciones de pérdidas anuales, comparando escenarios con y sin controles, tal y como se ilustra en ejemplos de cuantificación de robo de portátiles y seguros cibernéticos.³¹³²³³³⁴³⁵³⁶³⁷

23 <https://blackhat.com/html/sector-presentations.html>

24 <https://www.youtube.com/watch?v=8nMfIR57tLg>

25 <https://www.cloudflare.com/es-es/learning/security/glossary/what-is-threat-modeling/>

26 <https://www.toreon.com/tmi-newsletter-27-unleashing-the-power-of-threat-modeling/>

27 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

28 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

29 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

30 <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

31 <https://www.youtube.com/watch?v=8nMfIR57tLg>

32 <https://atlansec.es/es/blog/posts/16-03-2025/>

33 <https://www.cloudflare.com/es-es/learning/security/glossary/what-is-threat-modeling/>

34 <https://www.fairinstitute.org/state-of-crm-2025>

35 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

36 [https://www.fairinstitute.org/hubfs/FAIR Institute -- Comply with ISO_IEC%2027001%20with%20FAIR%20\(March %202025\).pdf](https://www.fairinstitute.org/hubfs/FAIR%20Institute%20--%20Comply%20with%20ISO%2027001%20with%20FAIR%20(March%202025).pdf)

37 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

A nivel industrial, los informes de gestión de riesgo cibernético de 2025 señalan tres tendencias relevantes: la adopción creciente de FAIR como lenguaje común entre CISO, CRO y CFO; la integración de cuantificación de riesgos en decisiones de inversión en controles (segmentación Zero Trust, detección avanzada, continuidad de negocio); y el movimiento desde programas centrados en cumplimiento hacia el uso de la ciberseguridad como ventaja competitiva medible en resiliencia. Sobre este caldo de cultivo, FAIR-STRIDE se posiciona como enfoque pragmático para construir modelos de amenazas “relevantes para negocio”, lo que implica priorizaciones basadas en reducción cuantificada de pérdida, no sólo en severidad técnica.³⁸³⁹⁴⁰⁴¹⁴²⁴³

3. Dimensiones FAIR-STRIDE: autenticidad, integridad, no repudio, confidencialidad, disponibilidad y autorización

Aunque FAIR, en sentido estricto, modela riesgos como función de probabilidad y pérdida, y STRIDE clasifica amenazas según propiedades de seguridad violadas, en la práctica 2025-2026 se ha extendido la lectura FAIR-STRIDE como un marco de indicadores alrededor de seis propiedades: autenticidad, integridad, no repudio, confidencialidad, disponibilidad y autorización, alineadas con los tipos de amenazas STRIDE y los impactos C-I-A exigidos por ISO 27001.⁴⁴⁴⁵⁴⁶⁴⁷⁴⁸⁴⁹⁵⁰

En autenticidad, los indicadores tienden a medir la tasa de suplantación efectiva de identidades en canales críticos, asociando cada incidente a un coste financiero estimado que incluye fraude, costes de respuesta, sanciones y erosión de confianza, y para ello se combinan métricas técnicas (porcentaje de

38 <https://www.youtube.com/watch?v=EhQcKcfIbxY>

39 <https://fastercapital.com/topics/conducting-a-security-audit.html/1>

40 <https://www.fairinstitute.org/state-of-crm-2025>

41 <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

42 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

43 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

44 <https://www.purestorage.com/es/knowledge/stride-threat-model.html>

45 <https://www.toreon.com/tmi-newsletter-27-unleashing-the-power-of-threat-modeling/>

46 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

47 <https://www.fairinstitute.org/state-of-crm-2025>

48 [https://es.wikipedia.org/wiki/STRIDE_\(seguridad\)](https://es.wikipedia.org/wiki/STRIDE_(seguridad))

49 <https://blackhat.com/html/sector-presentations.html>

50 <https://www.youtube.com/watch?v=8nMfIR57tLg>

autenticaciones fuertes, tokens comprometidos, bypass de MFA) con la frecuencia de incidentes extraída de registros y de datos de terceros. En integridad, las organizaciones cuantifican el riesgo de manipulación de datos claves (por ejemplo, en registros financieros, sistemas industriales o sanitarios) mediante distribución de posible volumen de datos alterados, esfuerzo de corrección y potenciales sanciones, lo que a escala nacional se traduce en indicadores agregados por sector sobre fiabilidad de registros y tiempos de detección de alteraciones.⁵¹⁵²⁵³⁵⁴⁵⁵⁵⁶⁵⁷⁵⁸⁵⁹⁶⁰

El no repudio se contextualiza en términos de litigios y disputas regulatorias: se modelan escenarios donde la imposibilidad de demostrar quién hizo qué lleva a pérdidas por fraudes, multas por incumplimiento de requisitos de trazabilidad y costes legales, todo ello cuantificado vía FAIR y alimentado por amenazas de repudio identificadas con STRIDE. En confidencialidad, se combinan las clásicas violaciones de datos con impactos secundarios (multas, acciones colectivas, pérdida de clientes),

51 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

52 <https://atlansec.es/es/blog/posts/16-03-2025/>

53 <https://www.fairinstitute.org/state-of-crm-2025>

54 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

55 <https://www.fairinstitute.org/state-of-crm-2025>

56 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

57 <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

58 <https://blackhat.com/html/sector-presentations.html>

59 <https://www.youtube.com/watch?v=8nMfIR57tLg>

60 [https://es.wikipedia.org/wiki/STRIDE_\(seguridad\)](https://es.wikipedia.org/wiki/STRIDE_(seguridad))

siguiendo ejemplos detallados donde se estiman probabilidades de investigación regulatoria, sanciones y demandas, y se comparan escenarios mitigados con seguros o controles adicionales.⁶¹⁶²⁶³⁶⁴⁶⁵⁶⁶⁶⁷⁶⁸

La disponibilidad se vuelve, a partir de 2025, un tema nacional de infraestructura crítica, especialmente en sectores de energía, sanidad, transporte y administración electrónica, donde se modelan ataques de denegación de servicio y fallos operativos con métricas de tiempo de inactividad, usuarios afectados y coste por hora de caída, vinculados a planes de continuidad y objetivos de nivel de servicio impulsados por reguladores. La autorización, por último, se materializa en escenarios de elevación de privilegios y abuso de permisos, cuantificados según accesos indebidos a activos de alto valor, con énfasis creciente en controles de Zero Trust (segmentación, microperímetros, controles contextuales) como palancas con impacto medible en reducción de pérdida.⁶⁹⁷⁰⁷¹⁷²⁷³⁷⁴⁷⁵⁷⁶⁷⁷

61 <https://atlansec.es/es/blog/posts/16-03-2025/>

62 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

63 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

64 [https://es.wikipedia.org/wiki/STRIDE_\(seguridad\)](https://es.wikipedia.org/wiki/STRIDE_(seguridad))

65 <https://www.purestorage.com/es/knowledge/stride-threat-model.html>

66 <https://blackhat.com/html/sector-presentations.html>

67 <https://www.youtube.com/watch?v=8nMfIR57tLg>

68 <https://www.purestorage.com/es/knowledge/stride-threat-model.html>

69 <https://www.toreon.com/tmi-newsletter-27-unleashing-the-power-of-threat-modeling/>

70 <https://fastercapital.com/topics/conducting-security-risk-assessment.html/1>

71 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

72 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

73 <https://www.fairinstitute.org/state-of-crm-2025>

74 <https://www.youtube.com/watch?v=8nMfIR57tLg>

75 <https://blackhat.com/html/sector-presentations.html>

76 <https://www.youtube.com/watch?v=8nMfIR57tLg>

77 <https://www.youtube.com/watch?v=EhQcKcfIbxY>

4. De la organización al territorio: aplicación nacional en España

España se mueve en un ecosistema regulatorio europeo en el que ISO 27001, NIS2, DORA, los marcos de resiliencia financiera y las estrategias de ciberresiliencia nacional empujan hacia evaluaciones de riesgo basadas en impactos sobre confidencialidad, integridad y disponibilidad, con obligaciones de reporte y supervisión sectorial. En este contexto, la adopción de FAIR y de metodologías de cuantificación se presenta como vía para dotar de consistencia a los informes de riesgo que las entidades presentan a supervisores y para armonizar métricas entre sectores, tal y como explican documentos que describen el uso de FAIR para cumplir ISO 27001 y análisis académicos sobre su aplicación junto a STRIDE y otros métodos.⁷⁸⁷⁹⁸⁰⁸¹⁸²⁸³

La traducción FAIR-STRIDE a nivel nacional consistiría, esencialmente, en tres capas. Primero, una capa de modelado de amenazas por sector, donde se definen catálogos nacionales de escenarios STRIDE representativos para banca, energía, sanidad, transporte, administración y pymes, integrando amenazas clásicas con ataques emergentes (IA generativa, deepfakes, compromisos de cadena de suministro) bajo el mismo paraguas taxonómico. Segundo, una capa de parametrización FAIR, donde para cada escenario se recogen datos de incidentes, costes y frecuencias, ya sea de fuentes nacionales o europeas, para estimar distribuciones de frecuencia y pérdida que permitan obtener exposiciones anuales por sector y por tipo de propiedad afectada.⁸⁴⁸⁵⁸⁶⁸⁷⁸⁸⁸⁹⁹⁰⁹¹⁹²⁹³

78 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

79 <https://www.fairinstitute.org/state-of-crm-2025>

80 <https://atlansec.es/es/blog/posts/16-03-2025/>

81 <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

82 <https://blackhat.com/html/sector-presentations.html>

83 <https://www.youtube.com/watch?v=EhQcKcfIbxY>

84 <https://www.cloudflare.com/es-es/learning/security/glossary/what-is-threat-modeling/>

85 <https://www.cloudflare.com/es-es/learning/security/glossary/what-is-threat-modeling/>

86 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

87 <https://www.toreon.com/tmi-newsletter-27-unleashing-the-power-of-threat-modeling/>

88 <https://blackhat.com/html/sector-presentations.html>

89 <https://fastercapital.com/topics/conducting-a-security-audit.html/1>

90 <https://atlansec.es/es/blog/posts/16-03-2025/>

91 <https://fastercapital.com/topics/conducting-security-risk-assessment.html/1>

Y tercero, una capa de agregación macro, en la que se construyan indicadores de riesgo cibernético territorial (por comunidad autónoma, por clústeres industriales) que expresen tanto la exposición bruta como la reducción de riesgo atribuible a controles específicos (desde la adopción de Zero Trust en organismos públicos hasta la mejora de continuidad de negocio en infraestructuras críticas). Países que han avanzado antes en este camino, reforzando la resiliencia a nivel federal o nacional mediante estrategias de Zero Trust y planes estratégicos de ciberseguridad, muestran la importancia de vincular métricas técnicas con objetivos de resiliencia y prioridades presupuestarias, algo que FAIR-STRIDE facilita al proporcionar puentes entre amenazas y euros. En España, esta lógica encajaría con las iniciativas de digitalización segura, los esfuerzos de segmentación de red en organismos públicos y la presión regulatoria europea sobre sectores financieros y de servicios esenciales, que requieren justificar inversiones de forma cuantitativa y trazable.⁹⁴⁹⁵⁹⁶⁹⁷⁹⁸⁹⁹

5. España frente al mundo: convergencias, lagunas y oportunidades

Comparativamente, el uso de FAIR y de enfoques FAIR-STRIDE se ha extendido con más rapidez en entornos anglosajones, impulsado por comunidades profesionales y por informes de institutos especializados que documentan casos de éxito y tasas de adopción, con un papel protagonista de grandes organizaciones globales que utilizan la cuantificación para negociar presupuestos y justificar estrategias de control. En Europa continental, la presión regulatoria ha sido más fuerte en cumplimiento que en cuantificación, pero documentos recientes que conectan FAIR con ISO 27001 y análisis académicos que tratan FAIR, STRIDE y otros como parte de un mismo ecosistema metodológico empiezan a reducir esa brecha.¹⁰⁰¹⁰¹¹⁰²¹⁰³¹⁰⁴

92 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

93 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

94 <https://www.fairinstitute.org/state-of-crm-2025>

95 <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

96 <https://blackhat.com/html/sector-presentations.html>

97 <https://www.youtube.com/watch?v=EhQcKcfIbxY>

98 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

99 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

100 <https://trepo.tuni.fi/bitstream/10024/143248/2/KiviojaSini.pdf>

101 <https://blackhat.com/html/sector-presentations.html>

102 <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

103 <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

España se encuentra en una posición interesante: fuerte alineamiento con normativas europeas, un tejido de infraestructuras críticas modernizándose hacia Zero Trust y segmentación, y una comunidad profesional que ya discute IA, resiliencia digital y nuevas arquitecturas de seguridad en foros especializados, pero con margen para madurar en la cuantificación sistemática de riesgos más allá de matrices de calor. El salto cualitativo consistiría en institucionalizar indicadores FAIR-STRIDE a nivel nacional, exigiendo o al menos recomendando que las entidades clave expresen su exposición a riesgos de autenticidad, integridad, no repudio, confidencialidad, disponibilidad y autorización en términos financieros cuantificados, aprovechando la compatibilidad que FAIR ofrece con marcos como ISO y NIST.¹⁰⁵¹⁰⁶¹⁰⁷¹⁰⁸¹⁰⁹¹¹⁰¹¹¹¹¹²

Ello permitiría, por ejemplo, que el regulador comparase la contribución marginal de medidas de segmentación Zero Trust frente a inversiones en continuidad de negocio o en detección avanzada, a la luz de su impacto en la reducción de pérdidas anuales estimadas, no sólo de su atractivo conceptual. La ironía, por supuesto, es que para lograr semejante sofisticación cuantitativa haría falta, paradójicamente, menos amor al Excel por sí mismo y más amor a la disciplina: datos fiables, modelos

¹⁰⁴ <https://www.fairinstitute.org/state-of-crm-2025>

¹⁰⁵ <https://www.fairinstitute.org/state-of-crm-2025>

¹⁰⁶ <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

¹⁰⁷ <https://blackhat.com/html/sector-presentations.html>

¹⁰⁸ <https://www.youtube.com/watch?v=EhQcKcfIbxY>

¹⁰⁹ <https://www.cloudflare.com/es-es/learning/security/glossary/what-is-threat-modeling/>

¹¹⁰ <https://ciberseguridad.com/guias/prevencion-proteccion/cuantificacion-riesgo-cibernetico/>

¹¹¹ <https://ieeexplore.ieee.org/iel8/6287639/10820123/10909533.pdf>

¹¹² <https://www.fairinstitute.org/state-of-crm-2025>

transparentes y una cultura que acepte la incertidumbre como algo que se mide, no como algo que se esconde tras el color rojo del mapa de riesgos.¹¹³¹¹⁴¹¹⁵¹¹⁶¹¹⁷¹¹⁸¹¹⁹

¿Quieres que aterricemos esto en un set concreto de indicadores FAIR-STRIDE que podría adoptar, por ejemplo, un ministerio o una comunidad autónoma en España para pilotar un programa nacional de ciberresiliencia?

21222324252627282930

¹¹³ <https://www.datasunrise.com/es/centro-de-conocimiento/modelo-de-amenazas-stride/>

¹¹⁴ <https://www.youtube.com/watch?v=EhQcKcfIbxY>

¹¹⁵ <https://atlansec.es/es/blog/posts/16-03-2025/>

¹¹⁶ <https://www.cisecurity.org/insights/blog/fair-a-framework-for-revolutionizing-your-risk-analysis>

¹¹⁷ <https://www.illumio.com/es-mx/blog/cyber-resilience-cisa-strategic-plan-zero-trust-segmentation>

¹¹⁸ <https://es.slideshare.net/slideshow/la-metodologa-stride-enfocada-a-la-ciberseguridadpptx/261510179>

¹¹⁹ <https://cyberlideriamgzn.es/categoria/actualidad/page/4/>